

CO4 – AT02: Vulnerability Assessment Report

Answer-Preparation Study Outline (Not a Final Submission)

Course: Ethical Hacking (ITA1410) | Course Outcome: CO4 | Total Marks: 100

This assignment asks you to write a Vulnerability Assessment Report for ONE of the ten wireless-security case studies your faculty assigns (check which case number you were given). This outline shows the analysis structure and key concepts for every case so you can prepare regardless of which one you receive. Research each incident further yourself using credible sources, write the analysis in your own words, and complete the Code of Conduct declaration yourself.

1. TJX Companies Wireless Network Breach (2005–2007)

Incident context (from the assignment): Attackers gained unauthorized wireless access to TJX's retail network; investigations found WEP still in use during a delayed transition to WPA, with weak access controls.

Areas your report must analyze

- Why WEP is cryptographically broken and how attackers could passively crack it.
- The risk of a slow/incomplete migration from a weak to a strong encryption standard.
- Network segmentation between wireless retail networks and payment-processing systems.
- PCI DSS relevance — payment card data protection requirements.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Specifically recommend WPA2/WPA3 with enterprise authentication (802.1X), rogue-AP detection, and PCI DSS-aligned segmentation/monitoring controls.

Rubric emphasis: Identification of Wireless Vulnerabilities (20%) and Risk/Impact/Root-Cause Analysis (20%) — be specific about WEP's weaknesses, not generic.

2. Lowe's Wireless Network Intrusion (2003)

Incident context (from the assignment): Attackers compromised a single retail store's wireless network, which provided a path into the company's central systems and other store locations; attackers attempted to capture credit-card data.

Areas your report must analyze

- Why a single weak wireless access point can become a pivot point into a nationwide network.
- Lack of network isolation between store-level wireless and corporate/central systems.
- Point-of-sale (POS) segmentation as a specific control.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.

- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend authentication hardening, wireless isolation per store, firewall rules restricting store-to-core traffic, POS segmentation, and centralized/consistent access management across all locations.

Rubric emphasis: Linkage between the local wireless weakness and the wider corporate network exposure — this is central to the assignment question.

3. Firesheep and Public Wi-Fi Session Hijacking (2010)

Incident context (from the assignment): The Firesheep browser extension let attackers on the same open Wi-Fi capture unencrypted session cookies and impersonate logged-in users, exposing sites that only encrypted the login page.

Areas your report must analyze

- Difference between encrypting only the login form vs. encrypting the entire session ('HTTPS everywhere').
- How open/shared Wi-Fi lets any nearby user sniff unencrypted traffic.
- Role of HSTS in preventing downgrade to unencrypted connections.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend full-session HTTPS enforcement, HSTS, wireless client isolation (so devices on the same AP can't see each other's traffic), VPN use on public networks, and user-awareness training.

Rubric emphasis: explain session-cookie protection and HSTS clearly — these are the specific controls the assignment question calls out.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

Incident context (from the assignment): A targeted campaign against executives/officials used compromised hotel Wi-Fi to present fake software-update prompts that delivered malware, abusing weak captive-portal and update-mechanism security.

Areas your report must analyze

- Captive portal design weaknesses and how attackers can inject fraudulent content.
- Why unsigned/unverified software updates over untrusted networks are dangerous.

- Guest network monitoring gaps that let a targeted attack go unnoticed.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend digital-signature verification for all software updates, DNS integrity protections, stronger guest-network monitoring, and restrictions on third-party Wi-Fi management access.

Rubric emphasis: this case rewards discussing a targeted/APT-style threat model, not just opportunistic attacks — note the 'selected guests' detail.

5. Marriott Wi-Fi Deauthentication Incident (2014)

Incident context (from the assignment): Marriott used equipment to send Wi-Fi deauthentication frames that blocked guests' personal hotspots; the FCC fined Marriott \$600,000 for interfering with lawful personal wireless use.

Areas your report must analyze

- How unprotected 802.11 management frames can be forged to disconnect legitimate users.
- Protected Management Frames (PMF) and how WPA3 mandates them.
- The legal/regulatory dimension — this case is as much about acceptable-use policy and law as technical control.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend PMF/WPA3 adoption, wireless intrusion detection to flag deauthentication abuse, and a clear, lawful acceptable-use policy for managing guest Wi-Fi interference.

Rubric emphasis: this case is about availability risk, not confidentiality — keep your impact analysis focused on denial-of-service and legal consequences.

6. Fake Wi-Fi Networks at the Republican National Convention (2016)

Incident context (from the assignment): A security experiment set up fake open wireless networks near the event; roughly 1,200 users connected within a day, showing how easily people trust unfamiliar network names.

Areas your report must analyze

- 'Evil twin' access points and SSID spoofing.
- Why devices auto-reconnecting to remembered network names is dangerous.
- Certificate warnings as a (often-ignored) user-facing defense signal.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend evil-twin detection systems, disabling auto-reconnect to open networks, enforced certificate validation, VPN use at public events, and attendee security-awareness messaging.

Rubric emphasis: this case is about human trust behavior as much as technical config — connect your analysis to user-awareness controls.

7. Wi-Fi Attacks Against Anti-Doping Officials (2016)

Incident context (from the assignment): Per a DOJ indictment, close-access teams targeted hotel Wi-Fi used by anti-doping officials in Rio de Janeiro and Lausanne to compromise credentials and access sensitive medical/anti-doping data.

Areas your report must analyze

- Nation-state/'close-access' operations vs. opportunistic cybercrime.
- Multifactor authentication and device certificates as credential-theft mitigations.
- Extra sensitivity of medical/personal data under privacy regulations.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend MFA, device certificates/802.1X, endpoint security for traveling staff, mandatory VPN configuration, and a travel-security policy for officials handling sensitive data.

Rubric emphasis: emphasize privacy/legal impact given the medical-data angle — the rubric explicitly rewards this dimension.

8. Attempted OPCW Wi-Fi Intrusion (2018)

Incident context (from the assignment): Dutch authorities disrupted a close-access operation against the OPCW; equipment for a Wi-Fi compromise was found in a vehicle near the building.

Areas your report must analyze

- Radio-frequency (RF) exposure beyond a building's physical perimeter as an attack surface.
- Enterprise Wi-Fi authentication (802.1X/EAP) and certificate validation to prevent rogue association.
- The overlap between physical security and wireless security in this case.

Suggested report structure

1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend 802.1X with strong EAP-TLS certificate validation, wireless intrusion prevention systems (WIPS), RF perimeter monitoring, and coordination with physical security/surveillance.

Rubric emphasis: this case rewards linking physical-security controls with wireless-security controls — don't treat it as a purely technical issue.

9. Australian Airport and In-Flight Evil-Twin Case (2024)

Incident context (from the assignment): A man was charged with allegedly running fake free Wi-Fi access points imitating legitimate networks at airports/other locations to capture personal data from connecting users.

Areas your report must analyze

- Evil-twin/SSID impersonation in a high-traffic transient environment (airports).
- Captive-portal spoofing to harvest credentials/personal data.
- Why automatic connection to 'known' SSIDs is a major enabler here.

Suggested report structure

1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend rogue-AP detection at the airport/airline level, staff response procedures for reported fake networks, mandatory certificate warnings, and passenger education on verifying official network names.

Rubric emphasis: recent/2024 case — cite it accurately if you research further, and focus on passenger-data exposure and detection response.

10. Network Rail Public Wi-Fi Portal Compromise (2024)

Incident context (from the assignment): Public Wi-Fi landing pages at 19 UK railway stations displayed unauthorized offensive content after the landing page was changed using a legitimate administrator account.

Areas your report must analyze

- Insider/compromised-credential risk — the change was made through a legitimate account, not a technical exploit.
- Privileged-access management (PAM) and multifactor authentication for admin accounts.
- Change-approval workflows and logging as detective/preventive controls.

Suggested report structure

- 1. Incident Background — summarize the timeline, organization, and technology involved in your own words.
- 2. Technical Understanding — explain the wireless/network mechanism that was abused (protocol, standard, or attack technique).
- 3. Vulnerability Identification — name the specific weaknesses (encryption, authentication, segmentation, configuration, monitoring gaps).
- 4. Risk, Impact & Root-Cause Analysis — likelihood, and operational/financial/privacy/legal/reputational impact; identify the root cause, not just the symptom.
- 5. Recommendations & Mitigation — specific, practical controls (not generic 'use strong security') tied to the root cause.
- 6. Conclusion — one paragraph summarizing overall risk posture and priority actions.
- Recommend MFA for all administrator accounts, formal change-approval processes, third-party supplier access review, centralized logging/alerting on portal changes, and an incident-response runbook for this scenario.

Rubric emphasis: this case is about access-control/account-security failure, not a wireless-protocol weakness — keep your vulnerability identification focused on privileged access, not encryption.

General Write-Up Checklist Before Submission

- Identify which single case number you were actually assigned and write the full report on that one.
- Research the case further from credible sources (news reporting, official statements, DOJ/FCC filings where applicable) and write findings in your own words — do not copy text.
- Use the six-section structure consistently: Background, Technical Understanding, Vulnerabilities, Risk/Impact/Root-Cause, Recommendations, Conclusion.
- Include a risk-rating summary table (Likelihood x Impact = Severity) as the rubric rewards a 'clear risk-rating summary'.
- Your name/reg. no. filled into the Code of Conduct and signed.